

Introduction

Introduction au risque opérationnel et à la résilience — corrigés

Corrigé

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Corrigés des exercices du chapitre

Corrigé de l'exercice 1 — La définition du risque opérationnel et sa spécificité causale

- (a) Les quatre causes énumérées sont : des *processus internes* inadéquats ou défaillants, des *personnes* inadéquates ou défaillantes, des *systèmes* inadéquats ou défaillants, et des *événements externes*. La définition porte sur les causes et non sur les conséquences en ce sens qu'elle décrit *ce qui produit* la perte (l'origine du dysfonctionnement), sans préjuger de *la forme que prend* la perte qui en résulte. Ainsi, une même cause — par exemple un système informatique défaillant — peut engendrer une conséquence financière (une perte de trading, une amende) et, séparément ou simultanément, une conséquence non financière opérationnelle (une interruption de service, une perte de données, une atteinte à la continuité d'activité) : c'est exactement le cas de la « défaillance de migration informatique de TSB Bank », dont la cause (système) a eu une conséquence essentiellement opérationnelle (accès privé à des dizaines de milliers de clients), quand un autre système défaillant pourrait tout aussi bien engendrer directement une perte financière chiffrée.
- (b) Une cause « non financière » est une cause qui ne réside pas dans la valeur ou le prix d'un instrument, d'une contrepartie ou d'un marché, mais dans le fonctionnement même de l'organisation : une personne qui commet une erreur ou une fraude, un processus mal conçu, un système qui tombe en panne, ou un événement externe (catastrophe naturelle, cyberattaque) ne sont, en eux-mêmes, ni des prix de marché ni des probabilités de défaut d'une contrepartie — à la différence des causes du risque de marché (mouvements de prix) ou de liquidité (assèchement du financement). Le chapitre nuance le cas du risque de crédit par « dans une certaine mesure » parce que le risque de crédit, bien que fondamentalement lié à la solvabilité financière d'une contrepartie, peut néanmoins avoir des causes partiellement non financières : un défaut peut résulter d'une défaillance opérationnelle de la contrepartie elle-même (fraude, erreur de gestion, rupture de chaîne d'approvisionnement) plutôt que d'une pure dégradation de sa situation financière — une frontière plus poreuse qu'avec le risque de marché ou de liquidité, dont les causes restent presque toujours de nature strictement financière (mouvements de prix, de taux, de flux de trésorerie).
- (c) L'inclusion du risque stratégique ou réputationnel compromettrait l'objectivité de la mesure car ces deux risques reposent sur des jugements intrinsèquement subjectifs et rétrospectifs : était-ce un « mauvais » choix stratégique ne se détermine souvent qu'*a posteriori*, au vu de résultats eux-mêmes influencés par de multiples facteurs externes non maîtrisables, et l'ampleur d'une atteinte « réputationnelle » dépend de perceptions de marché difficilement quantifiables de façon reproductible. Le risque légal, au contraire, se prête à une mesure aussi objective que les trois autres causes du risque opérationnel : l'exécution ou la rupture d'un contrat, l'issue d'un contentieux ou le montant d'une amende sont des faits vérifiables et chiffrables, de la même nature que les défaillances de personnes, processus ou systèmes déjà couvertes par la définition.
- (d) Une mauvaise exécution d'une stratégie par ailleurs saine se ramène directement à l'une des quatre causes de (a) : elle résulte de *personnes* qui exécutent mal (au niveau du conseil d'administration ou en dessous), de *processus* de mise en œuvre mal conçus ou mal suivis, ou de *systèmes* inadaptés au déploiement de la stratégie choisie — autant de défaillances objectivement identifiables une fois qu'on les cherche dans l'exécution plutôt que dans le choix initial. Un mauvais choix stratégique lui-même, en revanche, ne se ramène à aucune des quatre causes : il n'implique ni personne, processus ou système « défaillant » au sens opérationnel du terme (la décision a pu être prise par des personnes compétentes suivant un processus rigoureux), ni événement externe ; c'est un jugement erroné sur l'avenir, de nature radicalement différente d'une défaillance d'exécution.

Corrigé de l'exercice 2 — Les sept catégories de Bâle, leur poids relatif et quatre incidents emblématiques

- (a) Les sept catégories de niveau 1, dans l'ordre du chapitre, sont : la **fraude interne**, la **fraude externe**, les **pratiques d'emploi et sécurité du travail**, les **clients/produits/pratiques**

commerciales, les dommages aux actifs physiques, l'interruption d'activité et les dysfonctionnements des systèmes, et l'exécution, la livraison et la gestion des processus. Ces sept catégories sont « ensuite subdivisées en catégories de niveau 2, elles-mêmes illustrées par des exemples de niveau 3 » : la taxonomie descend ainsi d'une classification générale (niveau 1) vers des sous-types plus précis (niveau 2) puis vers des cas concrets illustratifs (niveau 3).

- (b) Les deux catégories qui expliquent 79 % de la sévérité totale sont **clients/produits/pratiques commerciales** et **exécution/livraison/gestion des processus**. La catégorie clients/produits/pratiques commerciales « représente plus de la moitié des pertes pour moins d'un quart de la fréquence » parce qu'elle concentre des événements peu nombreux mais individuellement très coûteux : la cause structurelle identifiée par le chapitre tient « notamment » aux « amendes réglementaires, parfois de plusieurs milliards de dollars », qu'elle inclut — un même type d'événement (mauvaise pratique commerciale sanctionnée) pouvant à lui seul représenter, comme l'illustre l'amende de Bank of America citée plus loin, plusieurs dizaines de milliards de dollars cumulés, sans qu'un nombre comparable d'événements soit nécessaire pour atteindre cette sévérité.
- (c) Bank of America (amende de 16,7 milliards USD pour la vente de titres adossés à des créances hypothécaires) illustre la catégorie **clients, produits et pratiques commerciales** : il s'agit d'une sanction réglementaire liée à la vente de produits financiers, exactement le type d'événement — amende réglementaire liée aux pratiques commerciales — identifié en (b) comme moteur de la sévérité de cette catégorie. Equifax (piratage des données de 145 millions de clients) illustre la catégorie **interruption d'activité et dysfonctionnements des systèmes**, puisqu'il s'agit d'une défaillance de sécurité informatique compromettant les systèmes de l'entreprise (à la limite, selon la définition retenue, de la fraude externe, l'attaque provenant d'un tiers malveillant ; mais la nature de l'incident — une brèche dans les systèmes — rattache l'événement en priorité à cette catégorie). La défaillance de migration informatique de TSB Bank illustre également la catégorie **interruption d'activité et dysfonctionnements des systèmes** : une migration informatique ratée est, par construction, un dysfonctionnement des systèmes ayant interrompu l'accès des clients. Jérôme Kerviel (4,9 milliards d'euros de pertes de trading non autorisé) illustre la catégorie **fraude interne** : un employé de l'organisation elle-même (« interne ») a contourné les contrôles pour engager des positions non autorisées, la définition même de la fraude interne.
- (d) Au sens strict de la définition du BCBS, la perte de 3,5 milliards USD de capitalisation boursière subie par Equifax est une *conséquence* du risque opérationnel, non une cause : la cause est le piratage lui-même (une défaillance de systèmes, éventuellement combinée à un événement externe si l'attaque est le fait d'un tiers), tandis que la perte de valeur boursière est l'une des « conséquences [...] financières » évoquées à l'exercice 1(a), au même titre qu'une amende ou une perte de trading. Le délai de deux mois avant la révélation du piratage est vraisemblablement un facteur aggravant de cette conséquence parce qu'il a retardé l'information du marché et des personnes concernées : plus l'écart entre la survenance de l'incident et sa révélation publique est long, plus le marché est susceptible d'interpréter ce délai lui-même comme un signal négatif supplémentaire (gestion de crise défaillante, risque de dissimulation), ce qui amplifie la perte de confiance et donc la perte de capitalisation boursière, indépendamment de la gravité intrinsèque du piratage.

Corrigé de l'exercice 3 — Cadres de gestion, cycle en quatre étapes et caractéristiques structurantes

- (a) Les deux cadres ERM génériques cités sont la norme internationale **ISO 31000** et le référentiel **COSO ERM**. L'ISO 31000 a été « révisée en 2018 pour mettre l'accent sur la création de valeur », un déplacement d'orientation vers une vision plus positive du management des risques (au-delà de la seule prévention des pertes).
- (b) Les quatre activités du cycle sont : l'**identification** des risques, renvoyée au *chapitre 2* ; leur **évaluation** « en termes de probabilité et d'impact », renvoyée au *chapitre 3* ; leur **atténuation** « par des contrôles ou d'autres mesures », renvoyée au *chapitre 4* ; et leur **surveillance** continue. Le cycle « se referme » en ce que la surveillance continue « réinjecte[e] les enseignements dans la

prochaine identification » : les incidents et anomalies détectés lors de la surveillance deviennent eux-mêmes des intrants du prochain exercice d'identification, transformant la succession des quatre étapes en boucle itérative plutôt qu'en séquence linéaire à sens unique.

- (c) La **gouvernance du risque** recouvre la « répartition des rôles et responsabilités » au sein de l'organisation. La **culture et la conduite du risque** désignent les comportements et normes partagés qui conditionnent la façon dont le risque est perçu et géré au quotidien par l'ensemble du personnel. L'**appétit pour le risque** désigne le niveau de risque que l'organisation est disposée à accepter dans la poursuite de ses objectifs, servant de référence aux décisions de gestion.
- (d) Le risque opérationnel est **hétérogène** : « même au sein d'une catégorie, les événements diffèrent fortement (vol de carte bancaire contre rançongiciel) ». Il est **idiosyncratique** : « sa matérialisation dépend fortement de la capacité et de la volonté de chaque organisation à le gérer ». Il est à **queue épaisse** : « une multitude de petites pertes coexistent avec un petit nombre de pertes extrêmes, plusieurs ordres de grandeur au-dessus de la médiane ». Il est **interconnecté** avec les autres risques « via des événements frontières ». Il est **dynamique** : « sa nature évolue avec celle de l'activité et de l'environnement de l'organisation ». Un « événement frontière » est précisément défini par le chapitre comme « un risque de marché ou de crédit dont la cause est en réalité opérationnelle » : un événement qui se matérialise en apparence dans la sphère du risque de marché ou de crédit (une perte de trading, un défaut), mais dont l'origine véritable est une défaillance de personnes, de processus, de systèmes ou un événement externe.

2 Corrigé de l'exercice cumulatif

Corrigé de l'exercice 4 — Ce que cette introduction relie entre elles

- (a) Les quatre causes de la définition du BCBS — personnes, processus, systèmes, événements externes — ne sont pas des grandeurs centralisées comme un prix de marché ou une exposition de crédit agrégée : elles sont, par construction, *distribuées* dans l'ensemble de l'organisation — chaque service a ses personnes, ses processus, ses systèmes, et est exposé à des événements externes qui lui sont propres. Définir le risque par ces causes revient donc mécaniquement à en faire un risque dont la matérialisation « dépend fortement de la capacité et de la volonté de *chaque* organisation » — l'idiosyncrasie — puisque la qualité des personnes, processus et systèmes varie d'une organisation, et même d'une unité, à l'autre. C'est cette même distribution des causes qui explique que le risque « naît de chaque personne et de chaque processus » et ne peut donc « pas être centralisé » : une fonction centrale ne peut surveiller un prix de marché unique de la même façon qu'elle ne peut personnellement contrôler chaque processus opérationnel de l'organisation, d'où le principe que « tout le monde est un gestionnaire du risque ». Une définition centrée sur les *conséquences* (une perte financière ou opérationnelle donnée) n'aurait pas eu cette implication aussi directement : une conséquence financière, en tant que résultat agrégé, aurait pu tout aussi bien suggérer une mesure et une gestion centralisées, comme c'est le cas pour le risque de marché ou de crédit, dont les définitions se rapprochent davantage des conséquences (une perte de valeur, un défaut) mesurables de façon agrégée.
- (b) Le déséquilibre ORX — deux catégories concentrant 79 % de la sévérité pour une fraction minoritaire de la fréquence — est la signature empirique exacte de la définition de la « queue épaisse » donnée plus loin : « une multitude de petites pertes coexistent avec un petit nombre de pertes extrêmes, plusieurs ordres de grandeur au-dessus de la médiane ». Si fréquence et sévérité étaient proportionnelles catégorie par catégorie — c'est-à-dire si chaque catégorie contribuait à la sévérité totale dans la même proportion que sa contribution à la fréquence totale —, la distribution des pertes serait à queue fine, chaque perte individuelle restant d'un ordre de grandeur comparable à la médiane. Le fait, au contraire, qu'une catégorie comme clients/produits/pratiques commerciales pèse « plus de la moitié des pertes pour moins d'un quart de la fréquence » signifie que les pertes qui la composent sont, en moyenne, bien plus élevées que celles des autres catégories : c'est exactement la coexistence, au sein d'une même

catégorie, d'événements nombreux mais modestes et d'événements rares mais extrêmes (les amendes réglementaires de plusieurs milliards) qui définit une queue épaisse, et non une simple proportionnalité entre nombre d'événements et masse de pertes.

- (c) La coïncidence calendaire est frappante : les RPSMOR, « révisés en 2021 », et les Principes pour la résilience opérationnelle, publiés « en mars 2021 », émanent du même Comité de Bâle la même année. Combinée à la citation du BCBS — « la résilience opérationnelle est un résultat qui bénéficie d'une gestion efficace du risque opérationnel » —, cette simultanéité ne doit pas être lue comme la publication de deux cadres parallèles et indépendants, mais comme la publication, la même année, d'un cadre *historique* (le risque opérationnel, né de Barings en 1995, périodiquement mis à jour) et de son *prolongement conceptuel* (la résilience, un « résultat » de ce premier cadre, non un dispositif séparé). Pour un établissement, cela implique qu'il ne peut pas « construire sa résilience » comme un chantier indépendant, parallèle à sa gestion du risque opérationnel : sans un cadre de gestion du risque opérationnel mature — identification, évaluation, atténuation, surveillance, gouvernance — la résilience recherchée n'aurait rien sur quoi « résulter », puisqu'elle n'est, par la définition même du BCBS, que la conséquence observable d'une gestion du risque opérationnel qui fonctionne déjà bien.
- (d) La notion de « préjudice intolérable aux clients ou à l'intégrité du marché », qui définit les services opérationnels importants dans le cadre britannique, ne se limite pas aux causes strictement non financières (personnes, processus, systèmes, événements externes) de la définition officielle du BCBS : un préjudice « aux clients » évoque directement la confiance et la satisfaction de la clientèle — au cœur du risque réputationnel — et un préjudice à « l'intégrité du marché » évoque la conduite de l'établissement vis-à-vis du système financier dans son ensemble, deux préoccupations que la définition du BCBS « exclut explicitement ». En construisant son cadre autour de « services » définis par leur importance pour les clients et le marché plutôt qu'autour de « processus » définis par leur fonctionnement interne, l'approche britannique adopte donc, de fait, le point de vue *externe* (client, marché) que la définition officielle du BCBS avait pourtant écarté pour préserver l'objectivité de la mesure du risque opérationnel. Cette approche referme ainsi, au moins partiellement, l'écart signalé au début du chapitre entre la définition BCBS « étroite » et la pratique « la plupart des organisations financières incluent néanmoins l'évaluation et la gestion du risque réputationnel » : le cadre de résilience, en amont réglementaire cette fois (et non plus seulement au niveau des pratiques internes des établissements), institutionnalise cette préoccupation réputationnelle et de conduite que la définition du risque opérationnel proprement dite continue, elle, d'exclure.

3 Corrigé des applications en sciences économiques

Corrigé de l'exercice 5 — Concentration fréquence/sévérité entre les sept catégories de Bâle, chiffrées

Le portefeuille compte 1 000 événements pour 50 000 milliers de dollars de sévérité totale.

- (a) Les parts de fréquence et de sévérité de chaque catégorie sont :

Catégorie	Part fréquence	Part sévérité
Fraude interne	$15/1\,000 = 1,50\%$	$1\,200/50\,000 = 2,40\%$
Fraude externe	$410/1\,000 = 41,00\%$	$3\,800/50\,000 = 7,60\%$
Emploi et sécurité du travail	$85/1\,000 = 8,50\%$	$900/50\,000 = 1,80\%$
Clients/produits/pratiques commerciales	$140/1\,000 = 14,00\%$	$28\,500/50\,000 = 57,00\%$
Dommages aux actifs physiques	$10/1\,000 = 1,00\%$	$350/50\,000 = 0,70\%$
Interruption/dysfonctionnements systèmes	$95/1\,000 = 9,50\%$	$4\,250/50\,000 = 8,50\%$
Exécution/livraison/processus	$245/1\,000 = 24,50\%$	$11\,000/50\,000 = 22,00\%$

- (b) Les quatre catégories les plus fréquentes sont, par ordre décroissant : fraude externe (410), exécution/livraison/processus (245), clients/produits/pratiques commerciales (140), interruption/dysfonctionnements systèmes (95). Leur somme est $410 + 245 + 140 + 95 = 890$

événements, soit $890/1\,000 = 89,00\%$ de la fréquence totale. Ce portefeuille est donc **plus concentré** en fréquence (89,00 % sur quatre catégories) que les données ORX rapportées par le chapitre (75 %) : les quatre catégories les plus actives y pèsent proportionnellement davantage que dans la référence sectorielle.

- (c) Les deux catégories les plus sévères sont clients/produits/pratiques commerciales (28 500) et exécution/livraison/processus (11 000), pour une somme de $28\,500 + 11\,000 = 39\,500$ milliers de dollars, soit $39\,500/50\,000 = 79,00\%$ de la sévérité totale — **exactement** le chiffre de 79 % rapporté par le chapitre pour les données ORX. En ajoutant la fraude externe (3 800), la somme devient $39\,500 + 3\,800 = 43\,300$, soit $43\,300/50\,000 = 86,60\%$ de la sévérité totale — très proche, également, du chiffre de 86 % rapporté par le chapitre. Ce portefeuille reproduit donc quasiment à l'identique la structure de concentration de la sévérité observée par ORX, alors même que sa concentration de fréquence (b) est nettement plus marquée que celle d'ORX.
- (d) La sévérité moyenne par événement (sévérité totale / fréquence) de chaque catégorie, classée par ordre décroissant, est : clients/produits/pratiques commerciales $28\,500/140 = 203,571$ k\$/évt; fraude interne $1\,200/15 = 80,000$ k\$/évt; exécution/livraison/processus $11\,000/245 = 44,898$ k\$/évt; interruption/dysfonctionnements systèmes $4\,250/95 = 44,737$ k\$/évt; dommages aux actifs physiques $350/10 = 35,000$ k\$/évt; emploi et sécurité du travail $900/85 = 10,588$ k\$/évt; fraude externe $3\,800/410 = 9,268$ k\$/évt. La catégorie clients/produits/pratiques commerciales, avec une sévérité moyenne de 203,571 k\$ par événement — plus de deux fois supérieure à la deuxième catégorie la plus sévère en moyenne (fraude interne, 80,000 k\$) —, confirme bien, à partir des parts calculées en (a), la propriété rapportée par le chapitre : sa part de sévérité (57,00 %, largement supérieure à la moitié) coexiste avec une part de fréquence (14,00 %, inférieure au quart) — exactement la structure « plus de la moitié des pertes pour moins d'un quart de la fréquence » que le chapitre attribue à cette catégorie dans les données ORX.

Corrigé de l'exercice 6 — Tolérance à l'impact et services opérationnels importants, chiffrées

Les quatre services sont interrompus simultanément pendant 6 heures.

- (a) Coût de chaque service (coût fixe + coût variable $\times 6$) : paiements de détail $50 + 120 \times 6 = 50 + 720 = 770$ k\$; compensation interbancaire $200 + 300 \times 6 = 200 + 1\,800 = 2\,000$ k\$; courtage en ligne $30 + 60 \times 6 = 30 + 360 = 390$ k\$; service clientèle $10 + 15 \times 6 = 10 + 90 = 100$ k\$. Le coût total de l'incident est $770 + 2\,000 + 390 + 100 = 3\,260$ k\$.
- (b) Paiements de détail (tolérance 2 h) et compensation interbancaire (tolérance 4 h) ont **déjà dépassé** leur tolérance à l'impact après 6 heures d'interruption ($6 > 2$ et $6 > 4$). Courtage en ligne (tolérance 8 h) n'a **pas encore** dépassé sa tolérance : il lui reste $8 - 6 = 2$ heures avant de la dépasser. Service clientèle (tolérance 24 h) n'a pas non plus dépassé sa tolérance : il lui reste $24 - 6 = 18$ heures.
- (c) Clients affectés sur les 6 heures (clients/heure $\times 6$) : paiements de détail $25\,000 \times 6 = 150\,000$; compensation interbancaire $5\,000 \times 6 = 30\,000$; courtage en ligne $8\,000 \times 6 = 48\,000$; service clientèle $3\,000 \times 6 = 18\,000$. Le total est $150\,000 + 30\,000 + 48\,000 + 18\,000 = 246\,000$ clients affectés. Classé par coût décroissant : compensation interbancaire (2 000), paiements de détail (770), courtage en ligne (390), service clientèle (100). Classé par clients affectés décroissant : paiements de détail (150 000), courtage en ligne (48 000), compensation interbancaire (30 000), service clientèle (18 000). Le service le plus coûteux (compensation interbancaire) n'est **pas** le même que le service affectant le plus de clients (paiements de détail) : le premier a un coût variable élevé par heure malgré un faible nombre de clients (opérations interbancaires de montants unitaires élevés), tandis que le second touche un très grand nombre de clients pour un coût unitaire par client plus faible.
- (d) Coût à 2 heures (coût fixe + coût variable $\times 2$) : paiements de détail $50 + 120 \times 2 = 50 + 240 = 290$ k\$; compensation interbancaire $200 + 300 \times 2 = 200 + 600 = 800$ k\$; courtage en ligne $30 + 60 \times 2 = 30 + 120 = 150$ k\$; service clientèle $10 + 15 \times 2 = 10 + 30 = 40$ k\$. Le coût total à 2 heures est $290 + 800 + 150 + 40 = 1\,280$ k\$. L'économie réalisée par rapport au coût observé à 6 heures (3 260 k\$) est $3\,260 - 1\,280 = 1\,980$ k\$, soit $1\,980/3\,260 = 60,74\%$ du coût observé : contenir l'incident

dans la tolérance du service le plus exigeant aurait ainsi permis d'éviter plus de 60 % du coût total effectivement subi.

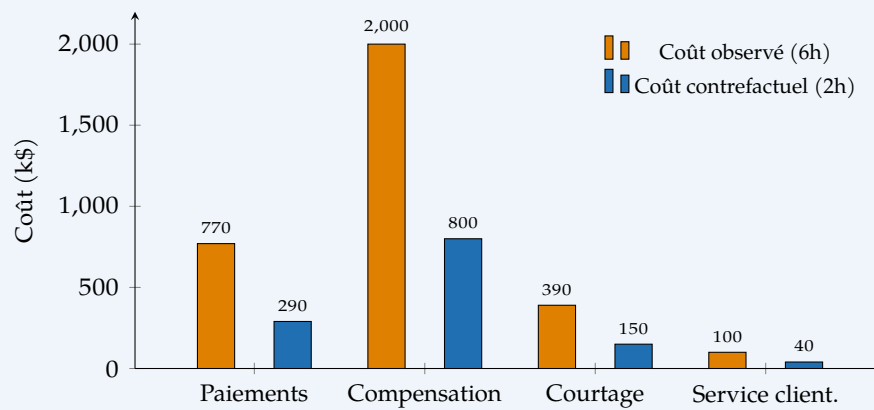


FIG. 1 : Coût de la perturbation des quatre services opérationnels importants, à la durée observée de 6 heures (orange) et sous le scénario contrefactuel où l'incident aurait été contenu en 2 heures, la tolérance du service le plus exigeant (bleu) — exercice 6.